

GUÍA MAESTRA DE DESARROLLO & BLUEPRINT E-COMMERCE

Checklist Técnico Completo, Estándar de Auditoría de Pagos, Seguridad y Cumplimiento Legal

Esta guía técnica consolida todos los requerimientos esenciales, buenas prácticas y especificaciones de arquitectura para la construcción de tiendas online de alto rendimiento. Sirve como base inmutable y pauta de verificación para futuros proyectos.

1. CHECKLIST MAESTRO DE 15 PUNTOS (SEO, UX, LEGAL Y RENDIMIENTO)

Punto / Requisito	Especificación Técnica & Justificación	Tipo / Área
1. Política de Privacidad	Página dedicada que detalla la recolección de datos, finalidades de uso, medidas de seguridad y ejercicio de derechos ARCO (Acceso, Rectificación, Cancelación, Oposición) conforme a la legislación local.	Obligatorio (Legal)
2. Compresión de Imágenes	Optimización de assets gráficos (WebP / compresión dinámica en CDN / pipeline con Pillow en backend) para garantizar tiempos de carga inferiores a 2 segundos en móvil y desktop.	Rendimiento & SEO
3. Términos y Condiciones	Reglas contractuales claras: proceso de compra, políticas de devolución, garantía legal, tiempos de despacho, limitaciones de responsabilidad y pasarelas de pago autorizadas.	Obligatorio (Legal)
4. Sitemap.xml	Archivo XML indexable ubicado en la raíz (/sitemap.xml) que lista todas las URLs públicas, fechas de modificación y prioridades de rastreo para Google y otros motores de búsqueda.	SEO Técnico
5. Meta Título por Página	Etiquetas <title> únicas y dinámicas para cada vista (Inicio, Catálogo, Fichas de producto, Checkout, etc.) bajo la estructura: '[Producto/Sección] [Categoría] [Marca]'.	SEO & UX
6. Estado de Error en Formularios	Validación inmediata en frontend (React Hook Form + Zod) y backend. Mensajes de error específicos en español, bordes en rojo y bloqueo de envíos con datos inválidos.	UX & Seguridad
7. Información de Contacto Real	Declaración transparente del modelo de negocio: venta 100% online con despacho a domicilio o dirección comercial física, junto a canales oficiales de soporte (WhatsApp y Correo).	Confianza & Legal
8. Banner de Consentimiento Cookies	Aviso flotante no invasivo con botones de 'Aceptar Todo' y 'Solo Necesarias', enlace a la política de privacidad y almacenamiento de la preferencia en localStorage.	Privacidad & UX
9. Texto Alternativo en Imágenes (alt)	Atributo 'alt' semántico y descriptivo en cada etiqueta del sitio para garantizar accesibilidad web (WCAG) y posicionamiento orgánico en Google Imágenes.	Accesibilidad & SEO
10. Página 404 Personalizada	Vista de error amigable con la identidad visual de la marca, mensaje explicativo y enlaces directos a las principales categorías para evitar que el usuario abandone el sitio.	UX & Retención
11. Página de 'Gracias' / Confirmación	Pantalla posterior a la compra con número de pedido, resumen de productos, desglose monetario, tiempos estimados de entrega y acceso directo a tracking / soporte.	UX & Posventa

12. Breakpoints Responsivos para Móvil	Diseño adaptable con navegación optimizada para pantallas táctiles (offcanvas, menús colapsables, botones de acción fijos en móvil y grillas fluidas).	UX Mobile-First
13. Analíticas & Medición	Integración de herramientas de seguimiento (Google Analytics 4 / Meta Pixel) respetando las preferencias de consentimiento de cookies del usuario.	Marketing & Datos
14. Favicon Personalizado	Isotipo oficial de la marca en formatos .ico y .png de alta resolución (32x32, 180x180 para Apple Touch) configurado en el head del HTML.	Branding
15. Imagen de Open Graph (og:image)	Metadatos Open Graph y Twitter Cards dinámicos para generar tarjetas visuales atractivas cuando se comparte el enlace en WhatsApp, Instagram, LinkedIn o Twitter.	Social Sharing & SEO

2. ESTÁNDAR DE PAGOS, CONCILIACIÓN BANCARIA Y AUDITORÍA FISCAL

Al integrar pasarelas de pago (Mercado Pago, Webpay Plus, Stripe), la base de datos debe capturar de forma inmutable los respaldos necesarios para responder ante auditorías tributarias (SII), reclamos bancarios (contracargos/chargebacks) y análisis de compras, cumpliendo rigurosamente la normativa PCI-DSS.

Campo en BD	Tipo	Descripción / Valor	Utilidad Principal
id / transaccion_id	String / Int	Identificador único de la transacción en la pasarela de pagos.	Conciliación inmediata
external_reference	String	Número de pedido interno (ej. RC-48291048) enviado a la pasarela.	Vínculo bidireccional
payment_method_id	String(50)	Franquicia o canal de pago (ej. visa, master, amex, webpay).	Auditoría de medio
payment_type_id	String(50)	Tipo de tarjeta/medio (credit_card, debit_card, account_money).	Perfil de compra
card_last_four	String(4)	Últimos 4 dígitos de la tarjeta (único dato de tarjeta permitido).	Comprobante cliente/banco
card_first_six (BIN)	String(6)	Primeros 6 dígitos para identificar banco emisor (Chile, Santander, etc.).	Prevención de fraude
cardholder_name	String(150)	Nombre del titular impreso en el plástico bancario.	Verificación de identidad
cardholder_identification	String(30)	RUT o número de documento del pagador.	Validación legal
authorization_code	String(100)	Código de autorización generado por el banco adquirente (Transbank/MP).	Prueba clave en disputas
cuotas / installments	SmallInt	Cantidad de cuotas elegidas en la transacción.	Condición financiera
total (Bruto)	Decimal	Monto total cargado y facturado al cliente final.	Monto tributario
comision_mp (Fee)	Decimal	Comisión de la pasarela + IVA de la comisión retenida en origen.	Gasto financiero contable
monto_netto (Net)	Decimal	Dinero líquido real que se transfiere a la cuenta de la empresa.	Flujo de caja neto
estado_detalle	String(100)	Código técnico de aprobación o rechazo (accredited, cc_rejected,...).	Soporte y analítica
ip_cliente & user_agent	IP / Text	Dirección IP pública y navegador del comprador al momento del pago.	Evidencia de contracargos
datos_pago_raw	JSON	Copia completa e inalterable de la respuesta JSON emitida por la API.	Respaldo forense total

Regla de Seguridad Crítica (PCI-DSS): NUNCA almacenar el número completo de la tarjeta (PAN de 16 dígitos), el código de seguridad (CVV de 3 o 4 dígitos) ni la fecha de vencimiento. Solo la pasarela mediante token efímero puede manipularlos.

3. REGISTRO DE USUARIOS, LOGÍSTICA Y VERIFICACIÓN EN DOS PASOS (2FA)

A. Registro de Usuarios y Verificación por Código (2FA):

- **Formulario Completo:** Captura Nombre, Correo, Teléfono, RUT, Dirección, Comuna, Ciudad y Región.

- **Verificación OTP de 6 dígitos:** Al registrarse se envía un código temporal al correo. La cuenta queda inactiva hasta ingresar el código correcto.
- **Panel Mi Cuenta:** Incluye historial de órdenes, tracking en vivo, libreta de direcciones y sistema de Favoritos.

B. Logística y Despacho:

- **Dirección de Envío Flexible:** Permite elegir la dirección principal de la cuenta o ingresar una nueva en el checkout.
- **Guardado Opcional:** Casilla para agregar la nueva dirección como alternativa en el perfil del usuario.
- **Separación de Campos:** Comuna y Ciudad deben residir en columnas separadas para integración con couriers (Starken, Blue Express, Chilexpress).
- **Control de Inventario Automático:** Descuento en tiempo real del stock de la variante comprada tras confirmarse el pago.

4. PANEL DE ADMINISTRACIÓN & DASHBOARD DE ESTADÍSTICAS (BI)

El panel de administración debe contar con un módulo analítico en tiempo real que permita evaluar la rentabilidad, productos estrella y comportamiento transaccional con filtros por período (7 días, 30 días, mes actual, año actual o histórico):

- **Tarjetas KPI Principales:** Ventas Totales Brutas, Ingresos Netos Líquidos (descontando comisiones), Comisiones Retenidas de Pasarela, Total Pedidos Pagados, Ticket Promedio (\$) y Tasa de Conversión (%).
- **Top Productos Más Vendidos:** Ranking visual por unidades vendidas, imagen miniatura, barras proporcionales de volumen y recaudación total en CLP por producto.
- **Ventas por Línea de Negocio:** Desglose porcentual y monetario por líneas de catálogo (ej. Ropa Urbana, Línea Formal, Drinkware, Diseños Personalizados en vivo).
- **Distribución de Medios de Pago:** Volumen de recaudación y cantidad de compras según franquicia (Visa, Mastercard, Webpay, Transferencia).
- **Despachos por Región:** Geografía de ventas para identificar las comunas y regiones con mayor volumen de pedidos a nivel nacional.
- **Embudo Operativo de Pedidos:** Conteo en vivo por estado: Pagados, En Proceso de Producción, Enviados a Courier, Entregados, Pendientes y Cancelados.
- **Auditoría de Transacciones:** Tabla con las últimas compras: número de orden, cliente, medio de pago (4 dígitos), monto bruto, comisión retenida, neto recibido y estado.

5. STACK TECNOLÓGICO & INFRAESTRUCTURA DE REFERENCIA

Capa / Componente	Tecnología Recomendada	Rol en la Arquitectura
Frontend SPA	React 18 + TypeScript + Vite + Bootstrap 5	Interfaz ultrarrápida, validación Zod y diseño responsivo.
Backend API	Django 5 + Django REST Framework + SimpleJWT	Lógica de negocio, autenticación segura y ORM robusto.
Base de Datos	PostgreSQL 16	Integridad transaccional ACID, JSONField y migraciones limpias.
Pasarela de Pago	Mercado Pago Checkout API / Webhooks IPN	Cobro directo con tarjeta, conciliación y eventos asíncronos.
Notificaciones	Django Core Mail / SMTP (Gmail o Dominio Corporativo)	Envío de códigos 2FA y comprobantes de compra con plantilla HTML.
Contenedores & Proxy	Docker Compose + Nginx + Unicorn + SSL	Despliegue reproducible, aislamiento y seguridad en producción.